

Security+ 2.4 · An Overview of Malware

Mestre CyberSec — Guia Completo CompTIA Security+ (SY0-701) · Aula 2.4 — An Overview of Malware (6:06) · [Vídeo no YouTube ↗](#)

Resumo da Aula: Malware = software malicioso. Categoriza: INTENÇÃO (spionagem, roubo, derrubar — DoS); FORMA (virus/worm/rootkit/trojan/keylogger/ransomware/stealer); ESCONDER (packer/compress/packing, polymorphic, metamorphic, fileless).

Highlights que a prova cobra

- Fileless = roda na memória, não toca em disco — invisível pro AV
- Polymorphic/métamorphobic muda de forma — evita assinatura

Dicas de prova & Cenários Típicos

- 'malware without a file on disk' = fileless malware

Cenário clássico de exame: Cenário: 'malware rodando sem arquivo no disco' = fileless malware.

 **Além do Vídeo: O que a CompTIA cobra na prova (Conceitos, Siglas e**

Armadilhas da Seção 2.4)

Por que este aprofundamento é cobrado no exame? O vídeo do Professor Messer (An Overview of Malware) resume os conceitos de forma ágil. Contudo, a banca examinadora oficial da CompTIA (SY0-701) exige raciocínio prático de engenharia de segurança, diferenciação entre protocolos concorrentes e aplicação em cenários corporativos reais. Entenda os conceitos complementares fundamentais:

- **Atores de Ameaça (Threat Actors): Nation-state / APT (Advanced Persistent Threat):** altamente financiado, sofisticado, motivado por espionagem geopolítica a longo prazo. **Cybercriminal:** motivado por lucro financeiro direto (ransomware, extorsão). **Hacktivist:** motivado por causas políticas ou ideológicas. **Insider Threat:** funcionário ou terceiro com acesso legítimo que abusa de privilégios por dolo ou negligência.
- **Engenharia Social e Variantes de Phishing:** **Phishing:** campanha em massa por e-mail. **Spear Phishing:** ataque direcionado a indivíduo ou empresa específica usando dados de OSINT. **Whaling:** direcionado a executivos do C-level (CEO, CFO). **Vishing:** phishing por voz/telefone. **Smishing:** phishing por SMS. **BEC (Business Email Compromise):** impersonação de diretoria para desvio de faturas ou transferências bancárias.
- **Tipos de Malware e Vetores de Ataque:**
 - *Ransomware:* cifra dados corporativos e exige resgate em criptomoeda.
 - *Trojan:* software aparentemente inofensivo que instala backdoors ocultos.
 - *Rootkit:* modifica o kernel do sistema operacional e se oculta de ferramentas antivírus comuns.
 - *Worm:* malware autorreplicável que se propaga sozinho pela rede sem intervenção humana.
- **Vulnerabilidades de Aplicação (OWASP Top 10):**
 - *SQL Injection (SQLi):* manipulação de queries de banco de dados por falta de sanitização/parametrização (prepared statements).
 - *XSS (Cross-Site Scripting):* injeção de scripts maliciosos (JavaScript) no navegador da vítima.
 - *CSRF (Cross-Site Request Forgery):* induz a vítima logada a executar ações indesejadas em uma aplicação web confiável.

⚠ **Armadilhas e Pegadinhas Clássicas da Banca:**

- Phishing não é mitigado apenas por filtros de e-mail; o controle humano fundamental é a simulação periódica de phishing e conscientização.
- Rootkits operam no nível de anel de privilégio (Ring 0 / Kernel), exigindo verificação de Secure Boot (TPM) para prevenção confiável.

✓ Perguntas de treino comentadas (10 questões)

Gabarito com resolução passo a passo e análise dos distratores no fim. Tente responder antes de olhar.

1. Malware que criptografa teus arquivos e exige pagamento pra devolver é:

- A)** Spyware
- B)** Ransomware
- C)** Rootkit
- D)** Worm

2. Qual tipo de malware se espalha automaticamente por redes sem necessidade de arquivo hospedeiro ou interação do usuário?

- A)** Worm
- B)** Trojan
- C)** Spyware
- D)** Adware

3. Atacante entra como usuário comum e vira 'Domain Admin'. Esse ganho de poder é:

- A)** Escalada de privilégio (privilege escalation)
- B)** Negação de serviço
- C)** Engenharia social
- D)** Sniffing

4. O framework NIST CSF organiza a segurança em 5 funções. Quais são?

- A)** Instalar, Atualizar, Testar, Auditar, Arquivar
- B)** Identificar, Proteger, Detectar, Responder, Recuperar
- C)** Planejar, Fazer, Checar, Agir, Revisar
- D)** Prevenir, Punir, Prever, Provar, Publicar

5. Cenário corporativo (An Overview of Malware): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 2.4), um analista avalia o seguinte requisito técnico: 'Fileless = roda na memória, não toca em disco — invisível pro AV'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Implementar a solução correspondente: Fileless = roda na memória, não toca em disco — invisível pro AV...
- B)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

6. Cenário corporativo (An Overview of Malware): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 2.4), um analista avalia o seguinte requisito técnico: 'Polymorphic/métamorphobic muda de forma — evita assinatura'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Permitir acesso compartilhado entre administradores com credenciais genéricas
- D)** Implementar a solução correspondente: Polymorphic/métamorphobic muda de forma — evita assinatura...

7. Cenário corporativo (An Overview of Malware): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 2.4), um analista avalia o seguinte requisito técnico: '"malware without a file on disk' = fileless malware'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Implementar a solução correspondente: 'malware without a file on disk' = fileless malware...
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

8. Cenário corporativo (An Overview of Malware): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 2.4), um analista avalia o seguinte requisito técnico: 'Cenário: 'malware rodando sem arquivo no disco' = fileless malware.'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Permitir acesso compartilhado entre administradores com credenciais genéricas
- D)** Implementar a solução correspondente: Cenário: 'malware rodando sem arquivo no disco' = fileless malware....

9. Cenário corporativo (An Overview of Malware): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 2.4), um analista avalia o seguinte requisito técnico: 'Fileless = roda na memória, não toca em disco — invisível pro AV'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Permitir acesso compartilhado entre administradores com credenciais genéricas
- D)** Implementar a solução correspondente: Fileless = roda na memória, não toca em disco — invisível pro AV...

10. Cenário corporativo (An Overview of Malware): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 2.4), um analista avalia o seguinte requisito técnico: 'Polymorphic/métamorphobic muda de forma — evita assinatura'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Implementar a solução correspondente: Polymorphic/métamorphobic muda de forma — evita assinatura...
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

GABARITO COMENTADO COM ANÁLISE DE DISTRATORES

1) B — Ransomware.

✓ **Por que está certa:** Ransomware sequestra os dados por criptografia e cobra resgate. Spyware espiona; rootkit se esconde no sistema com privilégio; worm se autopropaga na rede.

✗ **Por que as outras estão erradas:**

- *Spyware*: Não atende ao requisito técnico apresentado no cenário, contrariando as boas práticas e controles exigidos pelo exame CompTIA Security+.
- *Rootkit*: Não atende ao requisito técnico apresentado no cenário, contrariando as boas práticas e controles exigidos pelo exame CompTIA Security+.
- *Worm*: Não atende ao requisito técnico apresentado no cenário, contrariando as boas práticas e controles exigidos pelo exame CompTIA Security+.

2) A — Worm.

✓ **Por que está certa:** Worms se autorreplicam através de redes explorando vulnerabilidades, sem necessidade de hospedeiro ou ação do usuário.

✗ **Por que as outras estão erradas:**

- *Trojan*: Não atende ao requisito técnico apresentado no cenário, contrariando as boas práticas e controles exigidos pelo exame CompTIA Security+.
- *Spyware*: Não atende ao requisito técnico apresentado no cenário, contrariando as boas práticas e controles exigidos pelo exame CompTIA Security+.
- *Adware*: Não atende ao requisito técnico apresentado no cenário, contrariando as boas práticas e controles exigidos pelo exame CompTIA Security+.

3) A — Escalada de privilégio (privilege escalation).

✓ **Por que está certa:** Privilege escalation = subir de acesso baixo pra administrador. Virar Domain Admin dá controle do domínio inteiro (todas as máquinas e contas). É o passo 2 da cadeia.

✗ **Por que as outras estão erradas:**

- *Negação de serviço*: Não atende ao requisito técnico apresentado no cenário, contrariando as boas práticas e controles exigidos pelo exame CompTIA Security+.
- *Engenharia social*: Não atende ao requisito técnico apresentado no cenário, contrariando as boas práticas e controles exigidos pelo exame CompTIA Security+.
- *Sniffing*: Não atende ao requisito técnico apresentado no cenário, contrariando as boas práticas e controles exigidos pelo exame CompTIA Security+.

4) B — Identificar, Proteger, Detectar, Responder, Recuperar.

✓ **Por que está certa:** NIST CSF = Identify, Protect, Detect, Respond, Recover. É o 'checklist mestre' citado em quase toda vaga. (A versão 2.0/2024 somou uma 6ª função, Govern — mas o SY0-701 ainda cobra as 5.) Decorar essas dá ponto fácil na prova e na entrevista.

✗ **Por que as outras estão erradas:**

- *Instalar, Atualizar, Testar, Auditar, Arquivar*: Não atende ao requisito técnico apresentado no cenário, contrariando as boas práticas e controles exigidos pelo exame CompTIA Security+.
- *Planejar, Fazer, Checar, Agir, Revisar*: Não atende ao requisito técnico apresentado no cenário, contrariando as boas práticas e controles exigidos pelo exame CompTIA Security+.
- *Prevenir, Punir, Prever, Provar, Publicar*: Não atende ao requisito técnico apresentado no cenário, contrariando as boas práticas e controles exigidos pelo exame CompTIA Security+.

5) A — Implementar a solução correspondente: Fileless = roda na memória, não toca em disco — invisível pro AV....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 2.4 (An Overview of Malware): Fileless = roda na memória, não toca em disco — invisível pro AV.

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destroi a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

6) D — Implementar a solução correspondente: Polymorphic/métamorphobic muda de forma — evita assinatura....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 2.4 (An Overview of Malware): Polymorphic/métamorphobic muda de forma — evita assinatura.

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destroi a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

7) C — Implementar a solução correspondente: 'malware without a file on disk' = fileless malware....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 2.4 (An Overview of Malware): 'malware without a file on disk' = fileless malware.

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destroi a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

8) D — Implementar a solução correspondente: Cenário: 'malware rodando sem arquivo no disco' = fileless malware.....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 2.4 (An Overview of Malware): Cenário: 'malware rodando sem arquivo no disco' = fileless malware..

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destrói a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

9) D — Implementar a solução correspondente: Fileless = roda na memória, não toca em disco — invisível pro AV....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 2.4 (An Overview of Malware): Fileless = roda na memória, não toca em disco — invisível pro AV.

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destrói a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

10) C — Implementar a solução correspondente: Polymorphic/métamorphobic muda de forma — evita assinatura....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 2.4 (An Overview of Malware): Polymorphic/métamorphobic muda de forma — evita assinatura.

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destrói a

responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.